Grille de soutenance - Projet Web API

3ESGI-AL - Séances 9 et 10 - Soutenances individuelles (7 étudiants)

> Portée 2026-2027 : les réalisations s'arrêtent au **TP 6**. Les TP 1 à 3 forment le **socle** noté pleinement ; les TP 4, 5 et 6 sont notés **par paliers**.

Organisation des séances

- 7 passages de **20 min chrono** : **10 min de présentation + démo**, **10 min de Q&A notée** (4 questions tirées au sort, 2 fondamentaux et 2 cas limite, 2 pts chacune).
- **Lancement noté pendant l'ouverture** : chaque étudiant de la séance démarre son API depuis son `README` (ou `docker compose up`) sous les yeux du formateur, avant le premier passage (tout tourne en local sur le poste de l'étudiant). Le critère 1 est noté à ce moment.

> **Règle de backup technique** : si le lancement de l'API échoue pendant l'ouverture, l'étudiant retente sur le battement de fin de séance ; s'il échoue encore (ou si l'API tombe en début de passage, ≤ 2 min de tentative), l'étudiant présente en mode backup (captures horodatées de la dernière démo fonctionnelle, sortie de la suite de tests). Le critère 1 passe alors sur un barème réduit (max 1 pt). Si rien ne peut être montré : 0 pt sur le critère 1. Les autres critères sont notés sur ce qui est montré (code, spec, tests, `docs/api-design.md`).

Déroulé attendu de la présentation (10 min)

1. **Architecture (2 min)** : organisation du code, modèle de ressources (l'API tourne déjà depuis l'ouverture).
2. **Démo nominale (3 min)** : parcours CRUD, collection paginée + filtrée + triée, depuis la collection de requêtes (client au choix) ; suite de tests lancée.
3. **Cas d'échec (3 min)** : erreur de validation en `problem+json` ; **piège du sujet** rejoué (deux requêtes concurrentes) si réalisé ; `401` / `403` si réalisés.
4. **Choix justifiés (2 min)** : `docs/api-design.md`, stratégie de pagination, « Stratégie face au piège » et « Pourquoi REST ici » si rédigées.

Grille de notation (sur 20) = 12 pts projet + 8 pts Q&A

#	Critère	Séances	Pts	Nature
1	Lancement documenté et démo live	transverse	2	socle
2	Conception de l'API	S1, S2	3	socle
3	Robustesse : erreurs, validation, tests	S3	3	socle
4	Piège du sujet et requêtes conditionnelles	S4	2	paliers

#	Critère	Séances	Pts	Nature
5	Spec OpenAPI 3.1	S5	1	paliers
6	Sécurité	S6	1	paliers
	Sous-total projet		**12**	

Un critère à paliers non réalisé vaut 0 sur ce critère, **sans retrait ailleurs** : un manquement n'est jamais sanctionné deux fois (ni sur un autre critère, ni en Q&A).

1. Lancement documenté et démo live - 2 pts

Niveau	Description	Pts
Excellent	À l'ouverture, l'API démarre du premier coup depuis le README ou `docker compose up` ; la démo enchaîne sans accroc depuis la collection de requêtes	2
Bien	Démarre après une correction mineure (variable d'environnement, port) ; démo fluide	1,5
Moyen	Démarre avec difficulté ou mode backup ; démo partielle	1
Insuffisant	Rien ne peut être montré	0

2. Conception de l'API (S1, S2) - 3 pts

Niveau	Description	Pts
Excellent	≥ 4 ressources liées, URIs au pluriel sans verbe, niveau 2 de Richardson ; CRUD complet sur ≥ 2 ressources avec les bons codes (`201` + `Location`, `204`, `404`) ; une collection paginée (offset) + filtrable + triable avec tri stable (clé de départage), stratégie justifiée	3
Bien	Modèle cohérent et CRUD complet ; un défaut isolé (code de statut approximatif, tri non stable, `Location` absent)	2
Moyen	CRUD sur une seule ressource ou pagination / filtrage / tri incomplets ; plusieurs incohérences d'URIs ou de codes	1
Insuffisant	Pas de modèle de ressources exploitable, verbes dans les URIs, tout en `200`	0

3. Robustesse : erreurs, validation, tests (S3) - 3 pts

Niveau	Description	Pts
Excellent	Format `application/problem+json` unique sur toute l'API (handler central, aucune *stack trace*) ; validation sur toutes les écritures avec détail par champ ; `400` vs `422` distingués ; tests d'intégration (nominaux + 2 à 3	3

Niveau	Description	Pts
	cas d'erreur) qui passent d'une commande ; collection de requêtes versionnée avec les cas d'erreur	
Bien	Format unique et validation en place ; tests présents mais incomplets, ou une route d'écriture non validée	2
Moyen	`problem+json` partiel (certaines erreurs en texte brut) ou tests absents / rouges	1
Insuffisant	Pas de format d'erreur, pas de validation, pas de tests	0

4. Piège du sujet et requêtes conditionnelles (S4) - 2 pts, paliers

Palier	Description	Pts
Complet	Palier « Démontré » **et** `ETag` conditionnel (`304` / `412`) ou pagination par curseur opérationnels	2
Démontré	Scénario minimal du sujet **rejoué en live** (deux requêtes concurrentes, voir ci-dessous)	1,5
Écrit	« Stratégie face au piège » **et** « Pourquoi REST ici » rédigées dans `docs/api-design.md` et cohérentes, implémentation absente ou non démontrable	1
Non réalisé	Ni stratégie ni implémentation	0

Scénario minimal exigé pour « Démontré » (le reste des critères d'acceptation de `evals/projet-sujets.md` nourrit l'appréciation, pas le palier) :

Sujet	Scénario minimal
1. Bibliothèque	deux emprunts concurrents du même exemplaire → un `201`, un `409 problem+json`
2. Cinéma	deux clients sur le même siège → un `hold` gagnant, un `409 problem+json`
3. Salle de sport	deux réservations concurrentes sur la dernière place → une confirmée, une en liste d'attente

5. Spec OpenAPI 3.1 (S5) - 1 pt, paliers

Palier	Description	Pts
Complet	`openapi.yaml` valide (linter sans erreur) fidèle à l'API réelle, erreurs déclarées en `application/problem+json`, doc générée qui s'ouvre ; test de contrat bienvenu	1

Palier	Description	Pts
Partiel	Spec présente mais incomplète ou en écart avec le code, ou doc non générée	0,5
Non réalisé	Pas de spec	0

6. Sécurité (S6) - 1 pt, paliers

Palier	Description	Pts
Complet	Routes protégées (sans token → `401`) **et** une règle d'autorisation métier testée (mauvais rôle ou mauvais propriétaire → `403`) ; secrets hors du dépôt	1
Partiel	Authentification par token seule, ou règle d'autorisation non testée	0,5
Non réalisé	API ouverte	0

Rate-limit (`429` + `Retry-After`) et CORS ne sont pas notés ici : ils peuvent nourrir une question de la banque, jamais faire perdre de point sur ce critère.

Q&A notée - 8 pts (4 questions × 2 pts)

Tirage catégorisé. Les 12 questions de chaque sujet sont réparties en deux catégories :

Marqueur	catégories	Ce qui est évalué
[F]	Fondamentaux	Restitution du cours et application directe : l'étudiant doit savoir.
[C]	Cas limite / raisonnement	Situation non traitée telle quelle en TP : l'étudiant raisonne à chaud.

Barème générique par question : Excellent (exact, précis, argumenté) = 2 · Partiel (correct mais imprécis / non justifié) = 1 · Insuffisant (absent, hors sujet, faux) = 0.

Deux règles qui priment :

1. **Questions à deux volets** (marquées Y) : 2 volets traités = plein ; 1 seul volet correct et justifié = moitié ; 1 seul volet imprécis ou aucun = 0. Une demande de justification n'est pas un second volet.
2. **Questions de diagnostic** (formulées au conditionnel, surtout sur S4 à S6) : évaluent le raisonnement, pas ce qui a été implémenté. Une réponse correcte vaut le plein même si l'étudiant n'a pas terminé le TP correspondant. Ce qui a réellement été réalisé est noté **une seule fois**, aux critères 4 à 6.